

How to Spot and Stop DCE/RPC Attacks Like DCSync, DCShadow, and DPAPI in Active Directory?

 fidelissecurity.com/threatgeek/threat-detection-response/how-to-spot-and-stop-active-directory-attacks-faster-part-2

Arad Inbar

June 2, 2023



In the [previous blog](#), we described how to catch attackers targeting Active Directory (AD) in the reconnaissance stage, which is one of the earliest stages of the attack. We mainly focused on LDAP protocol, flagging suspicious queries.

In part two, we describe how to detect more advanced [Active Directory attacks](#) that are based on DCE/RPC protocol.

Within an AD environment, DCE/RPC protocol-based attacks pose a significant threat. They can compromise domain controllers, escalate privileges, or facilitate lateral movement within the network. Active Directory relies on RPC mechanism for various operations, making it an attractive target for adversaries.

DCSync Detection

About DSCync

Mitre: T1003.006

Attack name: [DCSync](#)

Common attacking tools: Mimikatz, Impacket

An attacker who compromised AD user account can pretend to be a Domain Controller (DC) and ask for sensitive information, provided the compromised account has the following permissions: “Replicating Directory Changes” or “Replicating Directory Changes All”.

The attacker will leverage the Directory Replication Service Remote Protocol, which is used for replication between domain controllers. In particular, they will use the DSGetNCChanges function, which retrieves data updates from the DC.

While the attacker typically uses Mimikatz in these attacks, they can use other tools as well. Regardless, the tool will ask the DC for user and computer NTLM hashes stored at the AD database file (NTDS.DIT). After the attacker gets the hashes, they can try to [brute force attack](#) offline and determine passwords. Or, if using krbtgt service account hash, the attacker can perform a golden ticket attack.

```
** SAM ACCOUNT **  
  
SAM Username       : Administrator  
User Account Control : 00010200 ( NORMAL_ACCOUNT DONT_EXPIRE_PASSWD )  
Object Security ID  :   
Object Relative ID  : 500  
  
Credentials:  
Hash NTLM: e19ccf75ee54e06b06a5907af13cef42
```

Figure: Attacker using Mimikatz with DC SYNC to discover NTLM hash of The Administrator

How to detect DCSync Attack?

1. DCE/RPC bind request for DRSUAPI interface:

2.DRSUAPI packet with DsGetNCChanges request:

```

> Transmission Control Protocol, Src Port: 14076, Dst Port: 49669, Seq: 3238, Ack: 2320, Len: 4
v Distributed Computing Environment / Remote Procedure Call (DCE/RPC) Request, Fragment: Single
  Version: 5
  Version (minor): 0
  Packet type: Request (0)
  Packet Flags: 0x03
  Data Representation: 10000000 (Order: Little-endian, Char: ASCII, Float: IEEE)
  Frag Length: 412
  Auth Length: 76
  Call ID: 6
  Alloc hint: 300
  Context ID: 0
  Opnum: 3
  [Response in frame: 163]
  Auth Info: SPNEGO, Packet privacy, AuthContextId(0)
v DRSUAPI, DsGetNCChanges
  Operation: DsGetNCChanges (3)
  [Response in frame: 163]
  Encrypted stub data: 8d8e1ef9f5832918c48dce120ce80208982ecc8d2762c072459d85aae0b5cce351df29

```

DCSHADOW Attack Detection

About DCSHADOW

Mitre: T1207

Attack name: DCShadow

Common Attacking tools: Mimikatz

In DCShadow attack, the attacker registers a machine as a DC, allowing the attacker to push changes to AD environment through replication between his rogue DC to the other DCs. The attacker will need to compromise a Domain Admin or Enterprise Admin account to perform the attack.

After registering the rogue DC, an attacker can change any AD object attributes in the domain.

The attack has a lot of similarities to DCSync attack. However, while DcSync gives the attacker the ability to read information from the DC, DCShadow allows the attacker to write and update the DC.

```

mimikatz # lsadump::dcshadow /push
** Domain Info **

Domain:          DC=,DC=com
Configuration:   CN=Configuration,DC=,DC=com
Schema:          CN=Schema,CN=Configuration,DC=,DC=com
dsServiceName:   ,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configuration,DC=,DC=com
domainControllerFunctionality: 7 ( WIN2016 )
highestCommittedUSN: 431127

```

DCShadow attack using Mimikatz

Detection Techniques for DCShadow

1. DCE/RPC bind request for DRSUAPI interface:

2. DRSUAPI packet with DrsAddEntry request:

```
> Transmission Control Protocol, Src Port: 49810, Dst Port: 49669, Seq
v Distributed Computing Environment / Remote Procedure Call (DCE/RPC)
  Version: 5
  Version (minor): 0
  Packet type: Request (0)
  > Packet Flags: 0x03
  > Data Representation: 10000000 (Order: Little-endian, Char: ASCII,
    Frag Length: 2204
    Auth Length: 76
    Call ID: 3
    Alloc hint: 2084
    Context ID: 0
    Opnum: 17
    [Response in frame: 3980]
  > Auth Info: SPNEGO, Packet privacy, AuthContextId(0)
  > DRSUAPI, DsAddEntry
```

3. DRSUAPI packet with DrsReplicaAdd request:

```
> Transmission Control Protocol, Src Port: 49810, Dst Port: 49669, Seq
v Distributed Computing Environment / Remote Procedure Call (DCE/RPC)
  Version: 5
  Version (minor): 0
  Packet type: Request (0)
  > Packet Flags: 0x03
  > Data Representation: 10000000 (Order: Little-endian, Char: ASCII,
    Frag Length: 412
    Auth Length: 76
    Call ID: 6
    Alloc hint: 289
    Context ID: 0
    Opnum: 5
    [Response in frame: 4045]
  > Auth Info: SPNEGO, Packet privacy, AuthContextId(0)
  > DRSUAPI, DRSUAPI_REPLICA_ADD
```

Reading Domain DPAPI BACKUP KEY FROM DOMAIN CONTROLLER

Mitre: T1555.003

Attack name: Domain DPAPI backup key extraction

Common Attacking tools: Mimikatz, SharpDPAPI, Impacket

Windows provides a mechanism for protecting asymmetric private keys, passwords, and confidential data. The mechanism, called DPAPI, performs symmetric encryption of data. Data Protection API (DPAPI) allows developers to encrypt data without the need for implementing the underlying encryption algorithm. Every windows user will have a DPAPI master key he can use to encrypt and decrypt data.

Common uses of DPAPI encryption include:

- Network passwords in Credential Manager
- Google Chrome cookies and login data
- Users pin and fingerprint in Windows 8
- WIFI passwords
- VPN passwords
- Email Account passwords

Detecting DPAPI attack

Attackers will use the LsaRetrievePrivateData function of the LSARPC interface in order to request the domain backup key from the DC. To identify the attacks, we will flag a DCE/RPC bind request for LSARPC interface, and a request for LsaRetrievePrivateData function from the DC.

To detect domain DPAPI backup key extraction attack, we will analyze all the traffic going into the DC.

We will look for attempts to get the domain DPAPI backup key from the DC.

We will capture the following packets for the DPAPI detection:

1. DCE/RPC bind request for LSARPC interface:

```

> SMB2 (Server Message Block Protocol version 2)
√ Distributed Computing Environment / Remote Procedure Call (DCE/RPC) Bind
  Version: 5
  Version (minor): 0
  Packet type: Bind (11)
  > Packet Flags: 0x03
  > Data Representation: 10000000 (Order: Little-endian, Char: ASCII, F
  Frag Length: 160
  Auth Length: 0
  Call ID: 2
  Max Xmit Frag: 4280
  Max Recv Frag: 4280
  Assoc Group: 0x00000000
  Num Ctx Items: 3
  √ Ctx Item[1]: Context ID:0, LSARPC, 32bit NDR
    Context ID: 0
    Num Trans Items: 1
    √ Abstract Syntax: LSARPC V0.0
      Interface: LSARPC UUID: 12345778-1234-abcd-ef00-0123456789ab
      Interface Ver: 0

```

2. LSARPC packet with LsaRetrievePrivateData API request:

```

> SMB2 (Server Message Block Protocol version 2)
√ Distributed Computing Environment / Remote Procedure Call (DCE/RPC) Request
  Version: 5
  Version (minor): 0
  Packet type: Request (0)
  > Packet Flags: 0x03
  > Data Representation: 10000000 (Order: Little-endian, Char: ASCII, F
  Frag Length: 136
  Auth Length: 0
  Call ID: 3
  Alloc hint: 112
  Context ID: 1
  Opnum: 43
  \[Response in frame: 383\]
  > Complete stub data (112 bytes)
  > Local Security Authority, lsa_RetrievePrivateData

```

Conclusion

Fidelis

Multi-layered Defense

Active Directory (AD) is the cornerstone of network management. It authenticates and authorizes users, provides for the storage and deployment of services such as file sharing, and more. It's the launch point from which attackers escalate privileges, and execute, data exfiltration.

Protecting AD is a prime target. But many tools fall short in the face of an imminent attack. And if they do, they can be network traffic and data protection tools.

That's where Fidelis Active Directory Intercept comes in.

See More. Stop Only with Active Directory Intercept.

Fidelis Active Directory Intercept uses detection and response technology with four just identify AD files. Intercept gives you exactly how, where, into your network, a ability to defend against.

Fidelis Active Directory Intercept™

Multi-Layered Active Directory Defense

